Key and Keystore Storage Standard (Dev, Test, Readiness, Production, DR)

Status: **Proposed** (2026-09-28). Author: `e1015974`. Applies to the Asset 9946 Mythos remediation repositories and the Report Scheduler (RS) .NET solution.

This document sets the target state for storing, delivering, and rotating cryptographic keys, keystores, keystore passwords, and application credentials. The five remediation plans in `docs/plans/` each link here from their **Key storage alignment** section.

> This document contains no secret values, ciphertext, or key material, and none may be added. See SECRET_ROTATION_AND_HISTORY_PURGE_RUNBOOK.md for the operational procedure.

---

1. Why this is needed

Each remediation plan moves secrets out of source. The replacement is an env var (`BICSSO_BO4_KEK`, `FIS_ENCRYPTION_KEY`), a JVM system property, or `catalina.properties`, and the plans only say it is "populated from the approved secret store". None of the plans defines:

- which secret store is used,
- whether key material differs per environment,
- who rotates it, and how often,
- how Harness or Jenkins gets the secret onto the host, or
- how exposed material is removed from JFrog artifacts and TFVC/Bitbucket history.

Without those controls, a Mythos rescan can pass while the key-management weakness (CWE-321/798) stays in place.

2. Normative references

Reference	What it requires
NIST SP 800-57 Part 1 Rev 5	Key lifecycle, cryptoperiods, separation of key types and purposes
NIST SP 800-53 Rev 5: SC-12, SC-13, SC-28, IA-5(7), CM-6, AU-2	Key establishment and management; approved crypto; protection at rest; **no embedded unencrypted static authenticators**; secure config; audit
PCI DSS v4.0: 3.6, 3.7, 8.3.2, 8.6.2, 8.6.3	Key-management procedures, split knowledge / dual control, cryptoperiods; app/system account passwords **not hardcoded** in scripts, config, or source; periodic rotation

Reference	What it requires
FFIEC IT Examination Handbook, Information Security	Encryption key management and access control expected of bank service providers
OWASP ASVS 4.0.3 V6.4, V14.1	Secrets in a vault/HSM, not in source or build artifacts; secure build/deploy
OWASP Secrets Management Cheat Sheet	Centralization, least privilege, rotation, audit, CI/CD handling
FIPS 140-3	Validated cryptographic modules (HSM) for production key-encryption keys
CWE-321 / CWE-798 / CWE-532	Hardcoded crypto key / hardcoded credentials / sensitive data in logs
CA/Browser Forum Ballot SC-081v3	Public TLS max lifetime: **200 days from 2026-03-15, 100 days from 2027-03-15, 47 days from 2029-03-15**. Treat it as the target for the internal CA too, which makes automated renewal mandatory

3. Core principles

1. **No secret in source, ever.** This covers TFVC and Bitbucket, and includes "encrypted" values whose key is also in source or derivable from the blob (f001, f006, f010, f014).
2. **Build once, deploy many.** Artifacts in JFrog are environment-agnostic and contain no secrets or keystores. Secrets are bound at deploy time (Harness) or at run time (the app reads Vault).
3. **Unique material per environment.** No key, keystore, password, or certificate is shared across environment tiers. Readiness is prod-like but is **not** prod.
4. **Machines read secrets; people generally do not.** Above Dev, humans get access only through audited break-glass.
5. **Rotation is the remediation; purge is hygiene.** Anything that was ever committed or published is compromised and must be rotated, whether or not history is purged.
6. **Fail closed.** A missing secret stops startup. There is no fallback to a default or embedded value (already done in the bic-sso and UserMaintenance fixes).
7. **Keys are for one purpose only.** A KEK does not encrypt data directly. A TLS keypair is not reused across SSO channels or tenants.

4. Environment matrix

Tier mapping: **Dev/Unit** = local and `Unit` modules; **Test** = `System`/`System_Test`/`Client_Test`; **Readiness** = `Readiness`; **Prod** = `Production`; **DR** = `DR`.

Control	Dev / Unit	System / Test	Readiness	Production	DR
Secret store location	Vault `dev` namespace/mount; local user-secrets allowed	Vault `sys` path	Vault `rdy` path	Vault `prd` path	Vault `dr` path (or `prd` replica, see below)
Key material	Synthetic, never derived from prod	Unique	Unique, prod-equivalent strength	Unique	Unique if hostname/identity differs; otherwise a replicated copy of prod under the same controls

Control	Dev / Unit	System / Test	Readiness	Production	DR
TLS certificate issuer	Dev CA (`*.fisdev.local`)	Internal CA	Internal CA, prod-like SANs	Production CA	Production CA
TLS cert lifetime	≤ 1 year	≤ 200 days	≤ 200 days (100 from 2027)	≤ 200 days (100 from 2027)	Same as prod
Private key storage	File allowed (git/tf-ignored)	Non-exportable: Windows `LocalMachine` store or PKCS#12 with ACL	Non-exportable	Non-exportable; HSM or Vault Transit for KEKs	Same as prod
Human read access	Developers	Tech lead / ops only	None; break-glass	None; break-glass with dual control	Same as prod
Machine authentication to Vault	Token / AppRole	AppRole or TLS-cert auth per service	AppRole/cert, CIDR-bound	AppRole/cert, CIDR-bound, response-wrapped `secret_id`	Same as prod
Password/credential rotation	On demand	≤ 180 days	≤ 90 days (mirrors prod)	≤ 90 days; **immediately on exposure**	With prod
KEK cryptoperiod (SP 800-57)	n/a	≤ 2 years	≤ 1–2 years	≤ 1–2 years originator-usage; rewrap data on rotation	With prod
Audit	Optional	Vault audit device on	Vault audit → SIEM	Vault audit → SIEM + alerting on reads outside pipeline identities	Same as prod
Change control	None	Jira ticket	Ticket + approval	CAB + dual control (PCI 3.6.1.2 / 3.7.6)	Same as prod
Who provisions	Developer	Harness pipeline	Harness pipeline	Harness pipeline + secret owner approval	Harness pipeline

Prohibited across tiers:

- A dev CA certificate or `fisdev.local` keystore in Readiness, Production, or DR. See §9.3, which covers **CRD Production**.
- One keystore password shared by more than one environment tier. See §9.3.
- Copying prod secrets down to lower tiers to reproduce a bug.

5. Where secrets may live (ranked)

Use the highest-ranked option the platform supports.

Rank	Pattern	Where it applies here	Notes
1	**App reads from Vault at run time** (KV v2 for credentials; **Transit** for encrypt/decrypt so the app never holds the KEK)	RS via `Fis.Foundation.Security.Vault` (already configured); Java via Spring Vault / Vault Java driver or Vault Agent template	Best. Supports rotation without redeploy. Use Transit for the Voltage `EncPwd` KEK (f006), the SSO `BO4SecretKey` KEK (f010), and the UserMaintenance/monitor passphrase (f001/f014)
2	**Platform key store, no password on disk**	.NET: Windows `LocalMachine\My` with non-exportable private key, ACL to service account (RS already does this). Tomcat on Windows: `certificateKeystoreType="Windows-MY"` (or `Windows-MY-LOCALMACHINE` on newer JDKs) via SunMSCAPI	Removes `keystorePass` entirely. Confirm the JDK and Tomcat versions bundled with BOE support it. On JDKs without `Windows-MY-LOCALMACHINE` (Java 8 included), `Windows-MY` reads the **service account's CurrentUser** store, so the certificate is imported into that profile rather than `LocalMachine` as §4 assumes; treat that as the rank-2 variant for those hosts
3	**File written by Harness at deploy time** with an ACL limited to the service account and Administrators	`catalina.properties` (`keystore.pass`), Tomcat `certificateKeystorePasswordFile` (confirm the bundled Tomcat version supports it), `.properties` read by Java tools	An acceptable interim control. The file must not be in the artifact and must not be overwritten by config deploys
4	**Process env var / JVM** `-D` injected by Harness/Jenkins for the process only	`BICSSO_BO4_KEK`, `FIS_ENCRYPTION_KEY`	Least preferred. Visible to the process owner, in crash dumps, and in `VersionLoggerListener` output (`logArgs="true"`). **Do not** set machine-level persistent env vars in Readiness/Prod/DR
✗	Source control, JFrog artifacts, Jenkins job config, Harness step scripts, wiki pages, tickets, email	—	Prohibited

6. Cryptographic minimums

Topic	Minimum
Symmetric encryption	AES-256-GCM (AES-128-GCM acceptable) with a 96-bit random nonce per message. **No ECB** (f006). No static or secret IV (the bic-sso `BICSSO_BO4_KEK_IV` pattern is interim only)
Integrity	AEAD (GCM) or encrypt-then-MAC. AES-CBC without a MAC (UserMaintenance `encrypt.java`) is interim only
Password-based key derivation	PBKDF2-HMAC-SHA256 ≥ 600,000 iterations (OWASP 2023) or Argon2id. Salt is random and **public**, never the secret (f001). *Note: For legacy Java runtimes (such as bundled BOE 4.3 Tomcat), use PBKDF2-HMAC-SHA256 or Vault Transit, as Argon2id lacks native JRE provider support.*
Asymmetric	RSA ≥ 3072 for new keys (2048 acceptable until rotation), ECDSA P-256+. RSA encryption padding **OAEP**, never PKCS#1 v1.5
Keystore format	PKCS#12 (`.p12`/`.pfx`). JKS/JCEKS are legacy and should not be used for new keystores
.NET protected configuration	`RsaProtectedConfigurationProvider` producing `aes256-cbc` + `rsa-oaep-mgf1p` (as Production already does). No `tripledes-cbc` / `rsa-1_5` sections (see §9.6)
TLS	TLS 1.2+ (1.3 preferred). Certificates from the tier-appropriate CA

7. Secret store options

HashiCorp Vault is the **primary** recommendation. RS already consumes it through `Fis.Foundation.Security.Vault`, and Harness has a native Vault connector. The alternatives are listed so Security can confirm or redirect.

Option	Strengths	Weaknesses	Use when
HashiCorp Vault (Enterprise, HSM auto-unseal)	Already in the RS stack; KV v2 versioning; **Transit** (EaaS) and **PKI** engines; AppRole/cert auth; namespaces per tier; Harness + Jenkins plugins	Needs a platform team; HSM seal needed for PCI-grade KEK custody	Default for all tiers
CyberArk (Central Credential Provider / Conjur)	Common enterprise PAM; strong for privileged DB and service accounts; password auto-rotation for Oracle accounts (DWNN, bodw/bocrd)	No Transit-style EaaS; separate integration per language	FIS mandates CyberArk for privileged account passwords. Use it for DB creds and keep Vault for keys
Harness built-in Secret Manager	Zero setup	Secrets are only available at deploy time; no run-time retrieval or Transit; stores Vault AppRole creds itself	Only for the Vault bootstrap credential (Harness requires this for AppRole)
Azure Key Vault (Managed HSM)	FIPS 140-3 L3 HSM; cert auto-renew	On-prem Windows hosts need network path and identity; new dependency	Only if the workloads move to Azure

Decision needed from Security/Platform: confirm the store, and confirm whether Vault is HSM-sealed and has Transit and PKI enabled. Until then, every plan targets Vault KV v2 paths of the form `secret/ibsmas/<tier>/<repo>/<name>`.

8. Toolchain controls

8.1 TFVC and Bitbucket (source)

- Add ignore rules (`.tfignore`, `.gitignore`) for `*.pfx *.p12 *.jks *.jceks *.keystore *.key *.pem *.snk AESKey*.txt EncPwd*.txt *.publishsettings`.
- Checked-in `*.snk` for strong-name signing is acceptable only if it is a public-key-only / delay-sign key.
- Branch policies reject PRs that fail the secret scan (§8.5).
- History purge: TFVC `tf destroy` requires a project collection administrator; Bitbucket uses `git filter-repo` plus a coordinated force-push, a Bitbucket admin cache GC, and re-clones. See the runbook. **Purge does not replace rotation.**

8.2 Jenkins (build)

- Builds need **no runtime secrets**. Any build that needs a keystore password to compile or package has a design defect.
- Pipeline credentials (Artifactory token, Bitbucket token, Checkmarx client secret) come from the Jenkins Credentials store or the HashiCorp Vault plugin through `withCredentials` / `withVault`. Build logs mask them.
- No secrets in `Jenkinsfile`, `buildParams.yml`, job parameters, or shared-library code.

- Maven and NuGet sources are **HTTPS only** (f091). Pin Maven ≥ 3.8.1, which blocks HTTP repositories by default.

8.3 JFrog Artifactory (artifacts)

- Artifacts must not contain secrets, keystores, `AESKey.txt`, `EncPwd.txt`, or environment-specific credential files. Add a Jenkins stage that unzips the artifact and runs the secret scanner with values suppressed, and fail the build on any hit.
- Turn on JFrog Xray / Advanced Security secrets detection on the `ibsmas` repositories.
- Use scoped access tokens with expiry, not user passwords or API keys.
- Inventory artifacts already published that contain exposed literals (bulkdecryption zips, the `dwbo-businessobjects-config` bundles, the `dw_ibs_MasDepJars` properties). Delete them, or move them to a restricted quarantine repository **after** rotation.

8.4 Harness (deploy)

- One **HashiCorp Vault connector per tier** (or one connector with tier-scoped paths), created at the org/project scope that matches the environment. Prod connectors cannot be selected by non-prod pipelines.
- Connector authentication: **AppRole**, with `secret_id` stored in the Harness built-in secret manager (a Harness requirement). The delegate runs on a host inside the tier's network.
- Reference secrets as `<+secrets.getValue("hashicorpvault://<connector>/ibsmas/<tier>/<repo>#<key>")>` or through Harness secret identifiers. Never echo them in step scripts. Use `Set-Content` to an ACL'd path, or pass them to the process environment only.
- Deploy steps that write `catalina.properties` or password files set the ACL in the same step: service account plus Administrators only, inheritance removed.
- Confirm the config deploy does not wipe host-provisioned files (open question from the businessobjects-config plan: `D:\SAP\Tomcat\conf\`).
- Certificates: import with a **non-exportable** private key, and grant the service account read on the key only. Prefer Vault PKI or the internal CA with auto-renewal before the SC-081 dates start to bite.

8.5 Checkmarx One (scan)

- Turn on **Secret Detection** (2ms engine) in addition to SAST and SCA in the Checkmarx One Jenkins plugin project configuration.
- Set a **break-build** policy on any hardcoded-secret or hardcoded-crypto-key finding in Readiness/Prod-bound branches (`develop`, `master`, TFVC release branches).
- Run a pre-merge scan of Bitbucket repos (Checkmarx 2ms CLI or gitleaks) in the PR build. For history, run 2ms against the full git history once per repo and record the result as purge-scope evidence.
- Suppress secret values in all reports that are exported or attached to tickets.

9. Application to current findings

Each plan's **Key storage alignment** section expands on these rows.

9.1 `dw_ibs_bulkdecryption` (f006, f079)

Target: the Voltage credential KEK lives in **Vault Transit**, and `EncPwd` is either replaced by a Vault KV read of the Voltage password or re-encrypted per tier. The interim (PR #43) static replacement key must be tier-specific and delivered via rank 3 or 4. The `dw_ibs_MasDepJars` copy (IBSDA-95438, **Cancelled**) stays exposed until the key is rotated. Reopen it, or record the rotation as its closure evidence.

9.2 `dwbo-bic-sso` (f010, f024, f091)

Target: `BO4SecretKey` (the BOE trusted-auth shared secret) is read from Vault KV per tier, which removes the KEK/IV layer entirely. Interim: `BICSSO_BO4_KEK` is sourced from Vault by Harness per tier. Replace the static IV with a random per-value IV when the ciphertext is regenerated. **Per-channel SLAPI RSA keypairs** (LP/CM/MAC4) need a Jira ticket; they are currently only "ops follow-up".

9.3 `dwbo-businessobjects-config` (f012, f013)

Blockers against §4:

- **CRD Production's `server.xml` points at `fisdev.local.pfx`, a dev keystore.** CRD Readiness and CRD System do too. If CRD Production is deployed, it serves TLS with a dev-issued identity.
- One keystore password literal is shared by BOE System, CRD Production, CRD Readiness, and CRD System. Another is shared by BOE Unit and CRD Unit.

Target: `certificateKeystoreType="Windows-MY"` (rank 2), with prod and readiness certificates issued per tier. Interim: `keystore.pass` in an ACL'd `catalina.properties` written by Harness (rank 3). Do not use `-Dkeystore.pass` (rank 4) unless `logArgs="false"`.

9.4 `dwbo-reportscheduler-monitor-config` (f014)

The planned fix replaces plaintext with ciphertext under the same self-keyed scheme. That is an interim control only. Target: the monitor reads the DWNN password from Vault KV (or CyberArk CCP, if mandated for Oracle privileged accounts). The DBA rotates DWNN and reviews its grants.

9.5 `dwbo-UserMaintenance` (f001, f025, f080)

`FIS_ENCRYPTION_KEY` / `com.fis.encryption.key` must be tier-specific and delivered by Harness (rank 3 or 4) from Vault. Target: Vault Transit replaces the local PBKDF2 passphrase. Sequence the AES-CBC → AES-GCM change (reverted IBSDA-89987) after f001. The f001 regression test (plan step 17) is still open.

9.6 Report Scheduler (.NET), `C:\projects\RS` — appendix

Already conforms (keep as the reference pattern):

- WCF service and client certificates resolve from `LocalMachine` by subject name. Production, DR, and Readiness use distinct identities (`bo43-rs-san-prd`, `-dr`, `-rdy`). Unit and System use `bo-san.fisdev.local`, which matches §4.

- Sensitive config sections (`connectionStrings`, `vaultSettings`, `secureAppSettings`) are encrypted with `RsaProtectedConfigurationProvider` using machine key container `RsSecureKey`.
- `Fis.Foundation.Security.Vault` is wired in (`vaultSettings`), so Vault is already a run-time dependency.

Gaps:

#	Gap	Evidence	Action
RS-1	`secureAppSettings` is encrypted with a `tripledes-cbc` session key wrapped with `rsa-1_5` in **9 Readiness and 3 System** config files. All Production (18), DR (12), and Unit (7) files, plus the other Readiness/System files, already use `aes256-cbc` + `rsa-oaep-mgf1p` (sweep 2026-09-28)	e.g. `Configs\Readiness\PDC8WMASIBSAP04\MasterControlProgram\...exe.Config` lines 42–47	Re-encrypt those 12 sections with the provider in its current configuration (`aspnet_regiis -pdf` then `-pef`, or `SectionInformation.ProtectSection`), matching prod. Readiness should mirror prod
RS-2	The `RsSecureKey` container is exported and imported across the server farm (`aspnet_regiis -px/-pi`), and that process is not documented	Same container name on every server	**Exception to §4 "non-exportable":** the container must be created exportable (`-exp`) so it can be shared across the farm. Compensating controls: keep the exported XML (it contains the private key) in Vault, not on a share. Use a distinct container per tier. Delete exported files after import. Grant the service account read-only (`aspnet_regiis -pa`)
RS-3	A private-key file `C:\projects\RS\Certs\bo-san.fisdev.local.pfx` is on a developer workstation	Not TFVC-mapped (`tf info`: no working folder mapping)	Dev-tier certificate, so low risk. Import it into the CurrentUser/LocalMachine store and delete the file, or keep it outside any workspace. Add `*.pfx` to `.tfignore`
RS-4	Secrets in `appSettings` that are not in a protected section	Review needed per file	Move them to `secureAppSettings` or read them from Vault. Mirror every change into `Configs\<Env>`
RS-5	Future Vault paths	—	Use `secret/rs/<tier>/...` with a per-tier AppRole bound to the service account's host

10. Compliance checklist per remediation PR

- ☐ No secret, keystore, ciphertext-with-derivable-key, or key file in the diff (Checkmarx Secret Detection or 2ms clean).
- ☐ The artifact built by Jenkins contains no secret (bundle scan clean).
- ☐ The secret source is named: Vault path per tier, or the documented interim rank.
- ☐ Material is distinct per tier: Dev/Unit, System, Readiness, Prod, DR.

- [ ] Harness provisioning step exists or a ticket is raised, with ACL and no log echo.
- [ ] A rotation owner is named, and rotation of the exposed values is ticketed.
- [ ] A history/artifact purge ticket exists (or an explicit risk-acceptance is recorded).
- [ ] The app fails closed when the secret is missing, and a test covers it.

11. Open questions for Security and Operations

Sent to Security, Operations, the BOE platform owner, and the DBA lead with this standard attached.

Security / Key Management

- **Q1:** Is HashiCorp Vault the sanctioned secret store for all tiers (Unit, System, Readiness, Production, DR)? Is it Enterprise with HSM auto-unseal, and are the Transit and PKI engines available to us?
- **Q2:** Is CyberArk (CCP/Conjur) mandated for Oracle privileged accounts (DWNN, bodw__/bocrd__)? If so, we will use it for DB credentials and keep Vault for encryption keys.
- **Q3:** Is DR a replica that shares Production secrets, or does it need its own identity? RS uses distinct DR certificates today.

BOE Platform Owner

- **Q4:** Is the CRD Production module of `dwbo-businessobjects-config` actually deployed? Its `server.xml` points at the `fisdev.local.pfx` dev keystore, as do CRD Readiness and CRD System. If it is live, we need production-CA and readiness-CA certificates issued before rotation.
- **Q5:** Which JDK and Tomcat versions ship on the BOE 4.3 hosts? This decides whether we can use the Windows certificate store (`Windows-MY`), which removes the keystore password entirely.
- **Q6:** Does the Harness BOE config deploy wipe `D:\SAP\Tomcat\conf`? If it does, host-provisioned `catalina.properties` would be overwritten.

Rotation Owners (Confirmation / Assignment)

- **Q7:** DBA: DWNN, bodw__/bocrd__ Oracle accounts, RS `BaseDbContext`.
- **Q8:** BOE admin: trusted-authentication shared secret (all 8 bic-sso environments), Tomcat keystores.
- **Q9:** Voltage admin: Voltage auth password/sharedSecret (bulkdecryption).
- **Q10:** RS team: the `RsSecureKey` machine key container and the Readiness/System `secureAppSettings` (12 files still use `tripledes-cbc` / `rsa-1_5`; Production and DR are already on AES-256/OAEP).

Pipeline & Toolchain

- **Q11:** Can Checkmarx One Secret Detection be turned on with a break-build policy for the IBSMAS projects, and JFrog Xray secrets detection for the `ibsmas` repositories?

- **Q12:** Who can run a Bitbucket history purge (filter-repo + force-push + GC) and a TFVC `tf destroy` once rotation is complete? This includes forks and mirrors, such as the `fis-anthropic-poc` evidence mirror: who controls it, and can it be purged or retired?

Rotation Owners (continued)

- **Q13:** UserMaintenance owner: `FIS_ENCRYPTION_KEY` / `com.fis.encryption.key` (f001) and re-encryption of the blobs it protects.